

CYB-043 : Gestion des logs et centralisation

Introduction Générale du Cours

Dans toute infrastructure numérique, les équipements ne cessent de parler. Chaque connexion réseau, chaque tentative d'authentification, chaque requête applicative, chaque erreur système génère un enregistrement — un log — qui constitue la mémoire vivante du système d'information. Ces traces, aussi discrètes que nombreuses, sont la matière première de la cybersécurité moderne : sans elles, l'analyste SOC est aveugle, le pare-feu est muet, et l'incident de sécurité passe inaperçu jusqu'à ce qu'il soit trop tard.

Ce cours aborde la gestion des journaux d'événements sous tous ses aspects : la compréhension du protocole Syslog et de ses mécanismes de transport, la mise en place d'une infrastructure de collecte centralisée, la normalisation et l'analyse des logs issus de sources hétérogènes, et enfin la configuration des systèmes d'alerte qui transforment un flux de données brutes en intelligence de sécurité exploitable.

Nous aborderons les solutions open source incontournables — rsyslog, syslog-ng, Graylog, ELK Stack — ainsi que les principes d'intégration avec les plateformes SIEM utilisées dans les SOC professionnels. L'objectif est de vous rendre opérationnel sur la conception, le déploiement et l'exploitation d'une infrastructure de gestion des logs conforme aux exigences réglementaires et aux bonnes pratiques de l'ANSSI.

Objectifs Pédagogiques du Module

À l'issue de ce cours, l'apprenant doit être capable de :

1. Maîtrise Conceptuelle et Architecturale

- Comprendre le rôle stratégique des journaux d'événements dans une démarche de cybersécurité.
- Distinguer les différents protocoles et formats de logs (Syslog, CEF, LEEF, JSON, Windows Event Log).
- Concevoir une architecture de collecte centralisée adaptée à la taille et aux contraintes de l'organisation.

2. Compétences Techniques et Opérationnelles

- Installer et configurer un serveur Syslog (rsyslog, syslog-ng) sur Linux.
- Configurer l'envoi de logs depuis des équipements hétérogènes (Linux, Windows, pare-feu, switches).
- Mettre en place un pipeline de collecte, normalisation et indexation avec Graylog ou ELK Stack.
- Sécuriser les flux de logs (chiffrement TLS, authentification mutuelle).

3. Expertise en Analyse et Détection

- Analyser les journaux d'événements pour identifier des comportements suspects ou des incidents de sécurité.
- Configurer des règles d'alerte pertinentes limitant la fatigue opérationnelle (faux positifs).
- Construire des tableaux de bord de supervision adaptés aux besoins d'un SOC.

4. Conformité et Documentation

- Définir une politique de rétention des logs conforme aux exigences légales (NIS2, DORA, RGPD).
- Documenter l'architecture de collecte et les règles d'alerte de manière maintenable.

Chapitre 1 : Fondements des Journaux d'Événements

1. Qu'est-ce qu'un Log ? Définition et Valeur

Un log (ou journal d'événements) est un enregistrement horodaté d'un événement survenu dans un système informatique. Cet événement peut être de nature très diverse : une connexion réussie ou échouée, l'exécution d'une commande, la modification d'un fichier, une erreur applicative, une alerte réseau. Le log contient au minimum trois informations : quand l'événement s'est produit (horodatage), où il s'est produit (identité de la source), et ce qui s'est passé (description de l'événement).

La valeur des logs en sécurité est multiple. En mode défensif, ils permettent la détection en temps quasi-réel des comportements anormaux. En mode réactif, ils constituent la matière première de l'investigation forensique après un incident — reconstruire la chronologie d'une attaque n'est possible que si les traces ont été conservées. Sur le plan réglementaire, la conservation des logs est imposée par de nombreuses législations, et leur absence lors d'un audit ou d'une enquête peut exposer l'organisation à des sanctions.

2. Le Protocole Syslog — Architecture et Fonctionnement

Syslog est le protocole standard de transmission des journaux d'événements dans les environnements Unix/Linux et sur les équipements réseau. Défini initialement de manière informelle, il a été standardisé par l'IETF dans la RFC 3164 (BSD Syslog, 2001) puis modernisé dans la RFC 5424 (2009), qui est la référence actuelle. Il repose historiquement sur UDP port 514 (transport sans garantie de livraison) mais supporte désormais TCP et TLS pour des transmissions fiables et chiffrées.

Un message Syslog RFC 5424 est composé de plusieurs parties : le champ PRI (priorité, calculé à partir de la facility et de la severity), la version du protocole, l'horodatage au format ISO 8601, le hostname de la source, le nom de l'application (APP-NAME), l'identifiant de processus (PROCID), un identifiant de message (MSGID), des données structurées optionnelles (STRUCTURED-DATA), et enfin le message lui-même (MSG). Cette structure, bien que plus verbeuse que la RFC 3164, garantit l'interopérabilité entre équipements et facilite le parsing automatisé.

3. Niveaux de Sévérité Syslog

Le protocole Syslog définit huit niveaux de sévérité, de 0 (Emergency) à 7 (Debug). La maîtrise de ces niveaux est indispensable pour configurer des filtres pertinents et éviter la collecte indiscriminée de messages sans valeur opérationnelle :

Niveau	Nom	Mot-clé	Description
0	Emergency	emerg	Système inutilisable — panne critique totale.
1	Alert	alert	Action immédiate requise — défaillance majeure.
2	Critical	crit	Condition critique — composant hors service.
3	Error	err	Erreur non fatale — service dégradé.
4	Warning	warning	Avertissement — situation anormale mais non bloquante.
5	Notice	notice	Événement normal mais significatif.
6	Informational	info	Message informatif sur le fonctionnement normal.
7	Debug	debug	Messages de débogage — à désactiver en production.

En production, il est recommandé de collecter les niveaux 0 à 4 (Emergency à Warning) sur le serveur central, et de conserver localement les niveaux 5 à 7 pour le dépannage. Le niveau Debug (7) ne doit jamais être transmis en production — il génère un volume de données excessif et peut exposer des informations sensibles dans les logs.

4. Les Facilities Syslog

La facility identifie la catégorie fonctionnelle de la source du message. Elle est encodée dans le champ PRI avec la severity ($PRI = Facility \times 8 + Severity$). Les principales facilities sont les suivantes :

Code	Facility	Sources typiques
0	kern	Messages du noyau Linux
1	user	Applications utilisateur générique
3	daemon	Démons systèmes (cron, sshd, ntpd...)
4	auth / security	Authentification, sudo, PAM, SSH
16-23	local0 à local7	Applications personnalisées, équipements réseau (Cisco, Fortinet...)

Les facilities local0 à local7 sont particulièrement importantes en sécurité : elles sont utilisées par convention pour les équipements réseau (Cisco utilise local6 et local7, Fortinet utilise local0). Configurer correctement la facility source permet de distinguer dans le SIEM les logs d'authentification des logs réseau, sans ambiguïté.

Chapitre 2 : Sources de Logs et Formats

1. Inventaire des Sources de Logs dans un SI d'Entreprise

Un SI d'entreprise génère des logs depuis une multiplicité de sources, chacune avec son format, son protocole et sa sémantique propres. L'une des premières difficultés de la gestion des logs est précisément cette hétérogénéité : un pare-feu Fortinet ne parle pas le même « dialecte » qu'un serveur Apache, qui lui-même diffère d'un contrôleur de domaine Windows. Le tableau suivant recense les principales sources et leurs caractéristiques :

Source	Type de logs	Format courant	Intérêt sécurité
Pare-feu (pfSense, FortiGate)	Connexions, blocages, NAT	Syslog / CEF	Élevé
Active Directory / LDAP	Authentification, GPO, modifications	Windows Event Log	Critique
Serveurs web (Apache, Nginx)	Requêtes HTTP, erreurs	Combined Log Format	Élevé
IDS/IPS (Suricata, Snort)	Alertes de détection d'intrusion	EVE JSON / Syslog	Critique
Serveurs Linux	Connexions SSH, cron, auth	Syslog (auth.log)	Élevé
Antivirus / EDR	Détections, quarantaines	JSON / Syslog / CEF	Élevé
Applications métier	Transactions, erreurs applicatives	JSON / Propriétaire	Variable
VPN SSL/IPsec	Connexions distantes, sessions	Syslog / RADIUS	Élevé

2. Le Format Windows Event Log

Les systèmes Windows n'utilisent pas nativement Syslog. Ils disposent de leur propre système de journalisation, le Windows Event Log, accessible via l'Observateur d'événements (eventvwr.msc) ou l'API Windows. Les événements sont organisés en plusieurs journaux : Security (authentifications, modifications de droits, accès aux objets), System (démarrages, arrêts, erreurs système), Application (messages des applications installées) et les journaux spécialisés (PowerShell, WMI, AppLocker, etc.).

Chaque événement Windows est identifié par un Event ID numérique. Certains Event ID sont des incontournables de la supervision sécurité. L'Event ID 4624 correspond à une ouverture de session réussie, le 4625 à un échec d'authentification, le 4648 à une tentative de connexion avec des identifiants explicites (souvent signe de Pass-the-Hash), le 4688 à la création d'un nouveau processus (crucial pour détecter l'exécution de malwares), et le 4740 au verrouillage d'un compte utilisateur.

Pour transmettre les logs Windows vers un serveur Syslog centralisé, on utilise des agents dédiés : NXLog (open source), Winlogbeat (de l'écosystème Elastic), ou l'agent Microsoft Azure Monitor Agent pour les environnements hybrides. Ces agents lisent les journaux Windows et les transmettent au format Syslog ou JSON vers le serveur central.

3. Formats de Logs Structurés

Face à l'hétérogénéité des formats natifs, l'industrie a développé des formats standardisés facilitant l'interopérabilité. Le CEF (Common Event Format), développé par ArcSight, est un format texte structuré qui encode chaque événement avec un en-tête fixe (version, deviceVendor, deviceProduct, deviceVersion, signatureId, name, severity) suivi d'extensions en paires clé-valeur. Il est aujourd'hui supporté nativement par la majorité des équipements de sécurité.

Le format JSON s'est imposé comme la référence pour les applications modernes et les équipements de nouvelle génération. Il offre une structure flexible, une lisibilité humaine et une facilité de parsing automatisé. Suricata, le moteur IDS/IPS open source, génère ses alertes au format EVE JSON, qui inclut pour chaque alerte l'horodatage, les IP source et destination, le protocole, la signature déclenchée et les métadonnées de flux.

Chapitre 3 : Configuration d'un Serveur Syslog

1. Choix de la Solution : rsyslog vs syslog-ng

Deux implémentations open source dominent le marché des serveurs Syslog sous Linux : rsyslog et syslog-ng. Rsyslog est l'implémentation par défaut sur la majorité des distributions Linux (Debian, Ubuntu, CentOS, RHEL). Il est particulièrement performant en volume (plusieurs millions de messages par seconde) et offre une syntaxe de configuration étendue (RainerScript) permettant des règles de filtrage et de routage sophistiquées. Syslog-ng est réputé pour sa flexibilité architecturale et la lisibilité de sa configuration, organisée en blocs sources / filtres / destinations clairement séparés, ce qui le rend plus facile à maintenir dans des configurations complexes.

Dans les deux cas, les fonctionnalités essentielles sont présentes : réception UDP et TCP, support TLS, filtrage par facility et severity, routage vers des fichiers, bases de données ou serveurs distants, et compression des logs archivés.

2. Installation et Configuration de rsyslog

Sur un serveur Debian/Ubuntu, rsyslog est généralement préinstallé. Si ce n'est pas le cas, l'installation s'effectue via `apt install rsyslog`. Le fichier de configuration principal est `/etc/rsyslog.conf`, complété par des fichiers dans `/etc/rsyslog.d/`. La configuration d'un serveur central de réception nécessite l'activation des modules d'entrée réseau.

Pour activer la réception UDP sur le port 514, on ajoute dans `rsyslog.conf` les directives `module(load="imudp")` et `input(type="imudp" port="514")`. Pour TCP, on utilise `module(load="imtcp")` et `input(type="imtcp" port="514")`. La réception TLS nécessite le module `imtcp` avec les paramètres de certificat : `StreamDriver.AuthMode="anon"` pour TLS sans authentification mutuelle, ou `x509/name` pour une authentification par certificat, ce qui est la pratique recommandée en production.

Une règle de routage typique en RainerScript peut se lire ainsi : si la facility est `auth` ou `authpriv`, les logs sont écrits dans `/var/log/auth.log` ; si l'host source correspond au pare-feu (`*.* ?RemoteHost`), les logs sont stockés dans un répertoire dédié `/var/log/remote/%HOSTNAME%/%PROGRAMNAME%.log`. Cette organisation par source facilite la recherche manuelle et améliore les performances d'indexation.

3. Configuration de syslog-ng

La configuration `syslog-ng` est organisée autour de quatre blocs fondamentaux : les sources (d'où viennent les messages), les filtres (quels messages sélectionner), les destinations (où les envoyer) et les chemins de log (qui associent sources, filtres et destinations). Cette séparation claire est l'un des atouts majeurs de `syslog-ng` pour les architectures complexes.

Un exemple de configuration typique pour un serveur central définit une source réseau `s_network` qui écoute en TCP sur le port 514, un filtre `f_security` qui sélectionne les messages de facility `auth`, une destination `d_security` qui écrit dans `/var/log/central/security.log`, et un log path qui associe ces trois éléments. L'ajout du chiffrement TLS se fait en ajoutant les paramètres `tls()` au bloc source ou destination, avec les chemins vers le certificat CA, le certificat serveur et la clé privée.

4. Sécurisation du Transport des Logs

La transmission des logs en clair sur le réseau représente un risque de sécurité souvent sous-estimé. Un attaquant ayant accès au réseau interne peut intercepter les logs et y lire des informations sensibles (identifiants, adresses IP internes, configurations) ou, pire, les altérer pour masquer ses traces. La sécurisation des flux de logs est donc une exigence non négociable dans un environnement de production.

Le chiffrement TLS s'applique aux transports TCP et RELP (Reliable Event Logging Protocol). RELP est à préférer à TCP simple car il garantit la livraison des messages avec acquittement — une propriété essentielle pour les logs critiques. La configuration TLS nécessite la génération d'une PKI interne dédiée aux logs (CA racine, certificats serveur et clients), un processus qui peut être automatisé avec des outils comme `cfssl` ou `step-ca`.

Une bonne pratique complémentaire est de dédier un VLAN ou un réseau hors-bande à la transmission des logs. Ce réseau, accessible uniquement des équipements sources vers le serveur central, limite la surface d'exposition et garantit que le trafic de supervision n'interfère pas avec le trafic de production.

Chapitre 4 : Centralisation et Normalisation des Logs

1. Architecture de Collecte Centralisée

Une infrastructure de gestion des logs mature repose sur une architecture en plusieurs niveaux. Le premier niveau est celui des sources : tous les équipements du SI (serveurs, postes, pare-feu, switches, applications) génèrent des logs et les transmettent vers le niveau supérieur. Le second niveau est celui des collecteurs intermédiaires (forwarders) : des instances rsyslog ou syslog-ng déployées sur des relais proches des sources, qui agrègent, filtrent et transfèrent les logs vers le niveau central. Le troisième niveau est le serveur central (ou cluster de serveurs) qui indexe, stocke et expose les logs pour l'analyse.

Cette architecture en couches présente plusieurs avantages. Elle limite le volume de trafic réseau vers le serveur central en permettant une pré-agrégation locale. Elle isole le serveur central des sources directes, réduisant sa surface d'attaque. Elle offre une tolérance aux pannes : si le serveur central est temporairement indisponible, les collecteurs intermédiaires peuvent stocker les logs localement (disk buffering) et les retransmettre à la reprise.

2. Graylog — Plateforme de Gestion des Logs Open Source

Graylog est une plateforme open source de gestion centralisée des logs, particulièrement adaptée aux environnements PME et ETI. Son architecture repose sur trois composants : le serveur Graylog (moteur de traitement et API REST), MongoDB (stockage de la configuration et des métadonnées) et OpenSearch ou Elasticsearch (indexation et recherche des logs). L'interface web de Graylog offre des capacités de recherche full-text puissantes, la création de tableaux de bord, la définition de flux (streams) pour organiser les logs par source ou par type, et un système d'alertes configurable.

La configuration d'un input Syslog UDP dans Graylog se réalise en quelques clics depuis l'interface : System > Inputs > Launch new input > Syslog UDP. On spécifie le port d'écoute (514 ou un port alternatif non privilégié comme 5140), le binding address, et les options de parsing. Graylog intègre nativement des extracteurs (extractors) qui permettent de parser des formats courants (CEF, GELF, JSON) et d'extraire les champs structurés pour les rendre interrogeables.

3. ELK Stack — Elasticsearch, Logstash, Kibana

L'ELK Stack (désormais Elastic Stack) est la solution de gestion de logs la plus déployée dans le monde, aussi bien en open source qu'en version commerciale. Elasticsearch est le moteur de recherche et d'indexation distribué qui stocke et expose les logs. Logstash est le pipeline de collecte, transformation et enrichissement des données. Kibana est l'interface de visualisation, de création de tableaux de bord et d'exploration des données.

Un pipeline Logstash typique pour la collecte de logs Syslog se compose d'un bloc input (Syslog sur le port 5144), d'un bloc filter qui applique des règles grok pour parser les messages bruts et extraire les champs IP source, port, facility, severity, et d'un bloc output qui transfère les événements enrichis vers Elasticsearch. Le langage grok, basé sur des

expressions régulières nommées, permet de parser des formats de logs complexes sans écrire de code, en réutilisant une bibliothèque de patterns prédéfinis.

4. Normalisation et Enrichissement des Logs

La normalisation est l'opération qui transforme des logs hétérogènes en un format unifié, facilitant la recherche et la corrélation. Elle consiste à extraire des champs sémantiquement équivalents (adresse IP source, utilisateur, action) depuis des formats différents et à les mapper vers un schéma commun. Des standards comme l'Elastic Common Schema (ECS) ou le OCSF (Open Cybersecurity Schema Framework) définissent ces schémas d'interopérabilité.

L'enrichissement va plus loin : il consiste à ajouter des informations contextuelles aux logs bruts. Une adresse IP peut être enrichie avec sa géolocalisation (base GeoIP MaxMind), sa réputation (intégration avec des flux de threat intelligence comme AlienVault OTX ou MISP), son propriétaire (lookup WHOIS). Un nom d'utilisateur peut être enrichi avec son département, son manager et son niveau de privilèges depuis l'Active Directory. Ces enrichissements transforment le log d'un enregistrement brut en un événement contextualisé, beaucoup plus exploitable par l'analyste SOC.

Chapitre 5 : Analyse des Journaux d'Événements

1. Méthodes d'Analyse des Logs

L'analyse des logs peut être abordée selon deux approches complémentaires. L'analyse réactive intervient après la détection d'un incident : l'analyste cherche à reconstituer la chronologie des événements, identifier le vecteur d'attaque initial (patient zéro), tracer les mouvements latéraux de l'attaquant et évaluer l'étendue de la compromission. L'analyse proactive vise à identifier des comportements suspects avant qu'ils ne dégénèrent en incident déclaré : elle repose sur la recherche de patterns anormaux, la comparaison avec des baselines de comportement normaux, et l'exploitation de flux de threat intelligence.

La recherche dans les logs s'effectue via des requêtes qui combinent filtres temporels, filtres sur les champs structurés (IP source, Event ID, utilisateur) et recherche full-text. Graylog utilise une syntaxe inspirée de Lucene, tandis que Kibana (Elastic) utilise KQL (Kibana Query Language) ou EQL (Event Query Language) pour des requêtes de séquences d'événements. Ces langages permettent d'exprimer des requêtes comme « trouver tous les Event ID 4625 générés depuis la même IP dans les 5 dernières minutes avec plus de 10 occurrences ».

2. Analyse des Logs d'Authentification

Les logs d'authentification sont parmi les plus riches en informations de sécurité. Une analyse systématique doit porter sur plusieurs scénarios. La détection de brute force

consiste à identifier des séquences d'échecs d'authentification répétés (Event ID 4625 sous Windows, messages pam_unix dans auth.log sous Linux) sur un même compte ou depuis une même source, en un temps court. Le seuil typique est de 10 échecs en moins de 5 minutes.

Le Pass-the-Hash et le Pass-the-Ticket sont des techniques d'attaque courantes dans les environnements Active Directory. Ils se manifestent dans les logs par des Event ID spécifiques : le 4648 (logon with explicit credentials) suivi d'un 4624 avec Logon Type 3 (réseau) depuis une machine qui n'initie normalement pas ce type de connexion est un pattern suspect à surveiller. Les connexions via Kerberos avec des tickets ayant des durées de vie anormalement longues (Ticket Granting Ticket de 10 ans — signe d'un Golden Ticket) sont également détectables dans les logs du contrôleur de domaine.

3. Analyse des Logs Réseau

Les logs réseau — pare-feu, IDS, NetFlow — permettent de détecter des comportements anormaux au niveau des flux de communication. Un scan de ports se manifeste par une source unique générant des connexions vers un grand nombre de destinations ou de ports différents en un temps court. Une exfiltration de données se traduit par un volume sortant anormalement élevé depuis un serveur qui ne devrait pas initier de connexions vers l'extérieur.

Le DNS tunneling est une technique d'exfiltration ou de command-and-control particulièrement discrète, qui encode des données dans les requêtes DNS. Il se détecte dans les logs DNS par des requêtes vers des sous-domaines inhabituellement longs (plus de 50 caractères), un volume élevé de requêtes DNS depuis un même client vers des domaines peu fréquentés, ou des requêtes pour des types de records inhabituels (TXT, NULL).

4. Corrélation Multi-Sources

La véritable puissance de l'analyse des logs réside dans la corrélation multi-sources : mettre en relation des événements issus de systèmes différents pour détecter des attaques qui, prises isolément, seraient invisibles. Un exemple classique : un utilisateur qui échoue à s'authentifier sur le VPN depuis une IP géolocalisée en Roumanie (log VPN), puis quelques minutes plus tard réussit une authentification (peut-être via une technique différente) et accède à un serveur de fichiers sensible (log AD), puis génère un flux sortant inhabituel de 2 Go (log pare-feu) — chacun de ces événements est bénin pris seul, mais leur corrélation temporelle et contextuelle constitue un signal d'alerte fort.

Les moteurs de corrélation des SIEM modernes permettent d'exprimer ces scénarios sous forme de règles (use cases) qui déclenchent une alerte lorsque la séquence d'événements est détectée dans une fenêtre temporelle définie. La qualité de ces règles — leur pertinence, leur précision, leur capacité à détecter sans générer trop de faux positifs — est le principal facteur de différenciation entre un SOC efficace et un SOC submergé par les alertes.

Chapitre 6 : Configuration des Alertes

1. Principes d'une Bonne Politique d'Alerte

Configurer des alertes efficaces est l'un des exercices les plus délicats en cybersécurité opérationnelle. Une politique d'alerte trop permissive génère un flux continu de faux positifs qui épuise les analystes et conduit à ignorer les alertes — c'est la « fatigue d'alerte », premier vecteur de non-détection des incidents réels. Une politique trop restrictive laisse passer des attaques réelles sous le radar. L'objectif est de trouver le juste équilibre entre sensibilité (détecter les vraies menaces) et spécificité (ne pas noyer l'opérationnel dans les faux positifs).

Toute règle d'alerte doit répondre à quatre questions fondamentales : quel événement ou pattern détecte-t-elle (condition) ? Dans quelle fenêtre temporelle s'applique-t-elle (temps) ? Quel est le seuil qui déclenche l'alerte (threshold) ? Quelle action en résulte (notification, ticket, isolation automatique) ? Ces quatre paramètres doivent être soigneusement calibrés à partir de l'observation du comportement normal (baseline) de l'environnement.

2. Catalogue de Scénarios d'Alerte Prioritaires

Le tableau suivant présente les scénarios d'alerte les plus importants à configurer en priorité dans un SIEM ou une plateforme de gestion des logs :

Scénario d'alerte	Criticité	Source de logs	Action recommandée
Échecs d'authentification répétés (> 10 en 5 min) sur un même compte	Élevée	AD / auth.log	Blocage temporaire, notification RSSI
Connexion depuis une géographie inhabituelle	Élevée	VPN / Firewall	Vérification de l'identité, MFA forcé
Activation du compte Administrator local sur un serveur	Critique	Windows Event Log	Isolation, investigation immédiate
Volume de données sortant anormalement élevé (> 1 Go en 1 h)	Critique	Firewall / DLP	Blocage flux, analyse des destinations
Scan de ports interne détecté (Nmap, masscan)	Élevée	IDS / Firewall	Identification de la machine source, investigation
Connexion RDP depuis le réseau interne vers un serveur critique hors horaires	Moyenne	AD / Firewall	Vérification auprès de l'équipe IT, journalisation renforcée
Détection malware par l'EDR sur un poste utilisateur	Critique	EDR / Antivirus	Isolation réseau, analyse forensique du poste

3. Configuration des Alertes dans Graylog

Graylog propose deux mécanismes d'alerte : les Event Definitions (définitions d'événements) et les Notifications. Une Event Definition combine une condition de déclenchement (count, statistical, correlation, field content), une fenêtre temporelle et des

filtres sur les champs structurés. Par exemple, une alerte sur les brute force SSH se configure avec une condition Count sur le stream Linux-Auth, filtrée sur le champ message contenant « Failed password », avec un seuil de 10 occurrences dans une fenêtre de 5 minutes, groupée par champ source.

Les Notifications définissent ce qui se passe lors du déclenchement de l'alerte : envoi d'un email, envoi d'un webhook (intégration Slack, PagerDuty, TheHive), ou création d'un ticket dans un outil ITSM. La bonne pratique est de distinguer les canaux de notification selon la criticité : les alertes critiques déclenchent un appel téléphonique ou une notification push immédiate, les alertes hautes créent un ticket prioritaire, les alertes moyennes alimentent une file de revue quotidienne.

4. Gestion du Cycle de Vie des Alertes

Une alerte ne se termine pas à sa génération. Elle suit un cycle de vie qui doit être formalisé : déclenchement, prise en charge par un analyste (acknowledgement), investigation, qualification (vrai positif ou faux positif), escalade si nécessaire, résolution et clôture. Chaque étape doit être tracée dans un outil de ticketing (Jira, TheHive, ServiceNow).

La gestion des faux positifs mérite une attention particulière. Chaque faux positif identifié doit déclencher une revue de la règle d'alerte correspondante : est-ce que la condition est trop large ? Le seuil est-il mal calibré ? Une exception est-elle nécessaire pour un comportement légitime spécifique ? Ce processus d'amélioration continue des règles est crucial pour maintenir la qualité opérationnelle du SIEM sur le long terme.

Chapitre 7 : Rétention, Conformité et Gouvernance des Logs

1. Exigences Réglementaires de Conservation

La durée de conservation des logs est encadrée par plusieurs réglementations qui s'appliquent de manière cumulative selon le secteur d'activité. La directive NIS2, transposée en droit français, impose aux entités essentielles et importantes de conserver les journaux de sécurité pendant une durée suffisante pour permettre la détection et l'investigation des incidents, généralement interprétée comme 12 mois minimum. Le règlement DORA, applicable aux entités financières depuis janvier 2025, impose une conservation de 5 ans pour les journaux relatifs aux incidents ICT.

Le RGPD ajoute une contrainte orthogonale : si les logs contiennent des données à caractère personnel (adresses IP des utilisateurs, identifiants de connexion, contenu de requêtes HTTP susceptible de révéler des comportements), ils sont soumis aux principes de limitation de la durée de conservation et de minimisation des données. Il est donc nécessaire de définir une politique de rétention qui respecte simultanément les exigences de sécurité (conserver suffisamment longtemps) et les exigences RGPD (ne pas conserver au-delà du nécessaire), et de documenter cette politique dans le registre des traitements.

2. Architecture de Stockage et Archivage

La volumétrie des logs en production peut être considérable. Un pare-feu d'entreprise génère facilement plusieurs dizaines de milliers d'événements par seconde en période de pointe. Une infrastructure de 500 serveurs peut produire plusieurs centaines de gigaoctets de logs par jour. La politique de stockage doit donc distinguer plusieurs niveaux : le stockage chaud (hot), où les logs des 30 à 90 derniers jours sont indexés et interrogeables en temps réel dans Elasticsearch ou Graylog ; le stockage tiède (warm), où les logs de 3 à 12 mois sont compressés et accessibles en quelques secondes ; et le stockage froid (cold ou archive), où les logs plus anciens sont archivés sur un support économique (stockage objet S3, bande magnétique) et restaurables en quelques heures.

L'intégrité des logs archivés est une exigence légale en cas de procédure judiciaire. Il est recommandé de calculer et de stocker des empreintes cryptographiques (hash SHA-256) des fichiers de logs archivés, et de les horodater via un service de tiers de confiance (RFC 3161). Cette chaîne de preuve garantit que les logs présentés lors d'une enquête n'ont pas été altérés après leur archivage.

3. Indicateurs de Performance de l'Infrastructure de Logs

La qualité d'une infrastructure de gestion des logs se mesure par des KPIs spécifiques. Ces indicateurs permettent de détecter les dérives (pertes de logs, latences excessives) et de justifier les investissements auprès de la direction :

KPI	Définition	Seuil recommandé
Volume de logs ingérés / jour	Nombre d'événements collectés par le SIEM	À établir comme référence (baseline)
Taux de perte de logs	Événements non reçus par le serveur central	< 0,1 %
Délai d'ingestion (latence)	Temps entre génération et indexation du log	< 60 secondes
Taux de faux positifs	Alertes générées sans incident réel	< 10 % des alertes
MTTA (Mean Time To Alert)	Délai entre incident et déclenchement de l'alerte	< 5 minutes
Durée de rétention des logs	Période pendant laquelle les logs sont disponibles	> 12 mois (NIS2, DORA)

Chapitre 8 : Cas Pratique — Déploiement d'une Infrastructure de Logs

1. Présentation du Scénario

La société IndustriA SA est une ETI de 300 salariés opérant dans le secteur industriel. Elle dispose d'un SI hybride : des serveurs Linux hébergeant ses applications de supervision, un Active Directory Windows, un pare-feu FortiGate en périmètre, et un réseau OT (Operational Technology) partiellement connecté au SI IT. Suite à un audit de cybersécurité, la DSI a été mise en demeure de mettre en place une centralisation des logs et un système d'alerte avant la fin du trimestre, condition préalable à l'obtention d'une certification ISO 27001.

La solution retenue est Graylog open source, déployé sur un serveur dédié Ubuntu 22.04 avec Elasticsearch et MongoDB. L'infrastructure devra collecter les logs de 15 serveurs Linux, du parc Windows (80 postes et 5 serveurs), du FortiGate, et devra implémenter un ensemble d'alertes prioritaires validées avec l'équipe sécurité.

2. Phase 1 : Déploiement et Configuration du Serveur Central

Le serveur Graylog est installé sur une machine dédiée avec 16 Go de RAM et 2 To de stockage SSD. Après l'installation des composants (Java, MongoDB, Elasticsearch, Graylog), la configuration de base fixe le secret de session, le hash SHA-256 du mot de passe administrateur, et l'URL de l'interface web. Un certificat TLS auto-signé est généré pour sécuriser l'accès à l'interface web.

Quatre inputs sont créés dans Graylog : un input Syslog UDP sur le port 5140 pour les équipements réseau, un input Syslog TCP TLS sur le port 6514 pour les serveurs Linux, un input GELF UDP sur le port 12201 pour les applications JSON, et un input Beats sur le port 5044 pour les agents Winlogbeat des machines Windows. Chaque input est associé à un stream dédié, permettant de segmenter les logs par type de source et d'appliquer des règles de rétention différenciées.

3. Phase 2 : Configuration des Sources

Sur les serveurs Linux, rsyslog est configuré pour transmettre tous les logs de facility auth et daemon vers le serveur Graylog en TCP TLS. La configuration dans `/etc/rsyslog.d/90-graylog.conf` active le module `omfwd` avec les paramètres TLS (certificat CA, certificat client, clé privée) et définit la règle `*.* action(type="omfwd" target="graylog.lan" port="6514" protocol="tcp" StreamDriver="gtls")`.

Sur les machines Windows, Winlogbeat est déployé via une GPO sur l'ensemble du parc. Sa configuration collecte les journaux Security, System et Application, ainsi que les journaux PowerShell/Operational et Sysmon (si déployé). Les événements sont transmis au format JSON vers le port Beats de Graylog. Le FortiGate est configuré dans Log & Report > Log Settings pour envoyer ses logs en Syslog vers l'IP du serveur Graylog sur le port 5140, avec facility `local0` et severity `information`.

4. Phase 3 : Implémentation des Alertes et Bilan

Cinq alertes prioritaires sont configurées en première phase : brute force SSH et RDP (10 échecs en 5 minutes), activation du compte Administrator local (Event ID 4722 + 4624 avec compte Administrator), connexion VPN hors géographie autorisée (pays différents de France dans les logs FortiGate), volume sortant anormal (plus de 500 Mo/heure depuis un serveur interne), et alerte IDS niveau critique depuis Suricata (severity 1 dans les logs EVE JSON).

Après deux semaines de fonctionnement, le bilan est révélateur : 847 alertes ont été générées, dont 89 % correspondent à des faux positifs liés à des scripts de sauvegarde mal configurés (volume sortant) et à des tests de l'équipe IT (connexions RDP hors horaires). Les règles sont affinées, les exceptions documentées, et le taux de faux positifs tombe à 12 % en semaine 4 — objectif à affiner progressivement pour atteindre les 5 % recommandés. Deux vrais positifs ont été détectés : une tentative de brute force SSH depuis une IP externe, bloquée et tracée, et un mouvement latéral suspect entre deux serveurs de développement.

Synthèse Générale du Module

Ce cours vous a conduit depuis les fondements du protocole Syslog jusqu'au déploiement opérationnel d'une infrastructure de gestion des logs en entreprise. La progression adoptée reflète la réalité du terrain : comprendre les protocoles et formats avant de configurer, configurer avant d'analyser, analyser avant de définir les alertes.

Trois grandes leçons synthétisent l'ensemble du cours. La première est que les logs n'ont de valeur que s'ils sont collectés, centralisés et conservés. Un log qui reste sur la machine locale qui l'a généré est inutile pour la supervision et disparaîtra avec elle en cas de compromission. La centralisation est la condition préalable à toute analyse sécurité sérieuse.

La deuxième leçon est que la qualité des alertes prime sur leur quantité. Mille alertes par jour dont 950 sont des faux positifs dégradent le niveau de sécurité réel en créant une désensibilisation des analystes. Investir du temps dans la calibration des règles, la définition des baselines et la gestion des exceptions est plus rentable que d'ajouter de nouvelles règles sans affiner les existantes.

La troisième leçon est que la gestion des logs s'inscrit dans une obligation de conformité croissante. NIS2, DORA, ISO 27001 — les référentiels convergent tous vers l'exigence d'une traçabilité documentée et maintenue. Mettre en place cette infrastructure n'est donc pas seulement une bonne pratique de sécurité : c'est une nécessité réglementaire pour toute organisation opérant dans un secteur régulé.

Glossaire

Terme	Définition
Agrégation	Regroupement de plusieurs événements similaires en un seul enregistrement pour réduire le volume de logs.
CEF	Common Event Format — format standardisé de log développé par ArcSight, largement adopté pour l'interopérabilité avec les SIEM.
Corrélation	Mise en relation de plusieurs événements issus de sources différentes pour détecter un comportement malveillant composite.
ELK Stack	Ensemble Elasticsearch + Logstash + Kibana — plateforme open source de collecte, d'indexation et de visualisation de logs.
Facility	Catégorie d'origine d'un message Syslog (noyau, démon, authentification...) encodée dans le champ PRI.
Forwarding	Transmission des logs d'un collecteur intermédiaire vers un serveur central ou un SIEM.
IOC	Indicator of Compromise — observable (adresse IP, hash, domaine) permettant d'identifier une compromission dans les logs.
Log	Enregistrement horodaté d'un événement généré par un système, une application ou un équipement réseau.
Normalisation	Transformation des logs de formats hétérogènes en un format unifié pour faciliter l'analyse et la corrélation.
Parseur	Module logiciel chargé d'extraire les champs structurés (IP, date, action...) d'un message de log brut.
Rétention	Durée pendant laquelle les logs sont conservés, soumise à des exigences légales et réglementaires.
RFC 5424	Standard IETF définissant le format des messages Syslog moderne, remplaçant la RFC 3164 (BSD Syslog).
SIEM	Security Information and Event Management — plateforme centralisant la collecte, la normalisation, la corrélation et l'alerte des événements de sécurité.
Syslog	Protocole standard (RFC 5424) de transmission des journaux d'événements entre équipements réseau et serveurs.
Syslog-ng	Implémentation évoluée du protocole Syslog, supportant TLS, le filtrage avancé et de multiples destinations de sortie.
TLS	Transport Layer Security — protocole de chiffrement utilisé pour sécuriser la transmission des logs sur le réseau.